安全自评报告

目　录

1 自评概述 **3**
1.1 评估对象与目标 3
1.2 总体评价 3
2 权限分级与隔离机制 **3**
2.1 用户与员工权限 3
2.2 三类 Agent 的权限边界 4
2.3 人工运维终端 4
3 安全防护措施 **4**
3.1 身份认证与凭据保护 4
3.2 敏感操作确认与防重放 4
3.3 交易一致性与幂等控制 5
3.4 数据存储与会话保护 5
3.5 页面内容与文件导出 5
3.6 运维 Agent 执行控制 6
3.7 安卓敏感输入、展示与本地恢复 6
3.8 安卓传输、更新与组件暴露 6
3.9 登录来源与设备审计 6
4 剩余风险与处置要求 **7**
4.1 多模态内容与模型外发（中） 7
4.2 运维宿主读取与网络权限（高，条件性） 7
4.3 同源脚本与明文字段保护（中，条件性） 7
4.4 发布配置与接口兼容性 7
4.5 安卓富文本与更新边界（中） 7
4.6 设备环境与本地解锁 8
5 安全验证结果 **8**
5.1 本地执行结果 8
5.2 关键验证结论 8
5.3 安卓核查与验证记录 9
6 后续安全维护 **9**

1 自评概述

1.1 评估对象与目标

本报告评估招财猫 Bank 的身份认证、权限分级、交易授权、智能体工具执行及数据保护措施，覆盖客户网页、安卓客户端、员工网页、银行服务，以及客户、员工和运维三类 Agent。自评日期为 2026 年 11 月 2 日。

自评围绕三个目标展开：业务操作由有效身份发起，执行范围与用户授权一致，敏感数据在传输、处理和存储过程中受到相应保护。检查内容包括实际业务代码、接口权限、会话与授权状态、数据库约束、模型调用链路、反向代理配置及本地自动化测试。安卓部分按当前 Kotlin 与 Jetpack Compose 工程核对，版本为 1.0.8，包名为 com.moneymeow.bank。

1.2 总体评价

系统以银行后端作为身份识别与业务校验边界，采用客户归属检查、员工角色权限、独立确认卡和参数绑定授权控制操作范围。客户、员工与运维 Agent 分别运行，工具能力按职责配置；资金操作在服务端重新校验，模型回复不作为账务结果依据。

当前代码已具备 CSV 公式前缀防护、导出身份绑定、关键写操作强制幂等、助手异常收口和精确跨域校验等措施。本轮本地回归未出现失败项。剩余风险主要集中在多模态内容外发、运维宿主权限、安卓富文本属性校验及环境配置落实，具体条件与处置要求见第 4 章。

2 权限分级与隔离机制

2.1 用户与员工权限

客户登录后访问本人账户、卡片、流水与助手会话。服务端根据会话确定客户身份，并在业务处理中检查对象归属，不能通过修改页面参数取得其他客户权限。每位客户只有一个储蓄资金账户，多币种余额和多张银行卡归属该账户，预算与卡片管理不额外创建资金账户。

工作人员权限分为客服、主管和运维三类。角色限制与工单归属、处理人、业务状态等条件共同决定操作是否可执行。

身份	主要操作范围	关键约束
客户	本人查询与经确认的业务办理	客户身份、对象归属、支付密码及业务规则
客服	客户资料查询、工单受理及限定代客操作	查询事由、关联工单、处理人及身份核验记录
主管	审批处置及受限规则调整	主管角色、审批状态及禁止自行审批等约束
运维	运行状态查询、运维工具及按配置启用的人工终端	运维身份、工具网关或终端专属控制

员工敏感接口可重新查询角色与认证版本。密码或角色发生变化后，旧认证版本失效。网页与安卓界面的本地校验用于输入提示和流程控制，不能替代后端授权；前端菜单与助手提示词用于呈现可用能力，后端接口承担实际权限校验。

2.2 三类 Agent 的权限边界

客户、员工和运维 Agent 使用独立服务进程及运行配置，分别采用 customer、staff、ops 会话命名空间。三者共享 DeepSeek Harness、桥接公共代码和银行服务，身份与工具权限分别验证。

客户 Agent 携客户身份调用银行业务接口；员工 Agent 使用员工身份及工作人员工具；运维 Agent 使用受控原生工具和运维风险网关。工具名单在配置与注册层进行一致性检查，未启用的工具不能依靠模型自行调用。

浏览器访问助手接口需要银行登录态，访问具体会话时再次核对所有者。内部工具与确认通道使用独立内部凭据。导入历史只提供普通文字上下文，不能导入可信工具回执或审批记录，也不能据此改变当前身份。

2.3 人工运维终端

人工终端通过独立开关启用，仅允许有效运维身份创建，要求服务以非 root 账号运行，并核对运维密码配置。终端子进程只继承必要环境变量，具有会话数、输入大小、输出缓存及空闲时间限制；退出登录后关闭对应会话。

人工终端直接接受运维人员输入，与 Agent 的逐工具审批分属不同通道。终端实际能力由运行账号权限决定，启用时须限制系统账号、工作目录和可访问资源。

3 安全防护措施

3.1 身份认证与凭据保护

客户会话使用随机令牌，服务端仅保存令牌的 SHA-256 摘要，并检查有效期、退出和撤销状态。客户网页令牌存于 sessionStorage，员工网页令牌存于内存，减少长期本地留存。

密码采用随机盐与 scrypt 派生，校验输入长度和允许的计算参数；旧摘要格式保留迁移兼容路径。登录与短信请求设有频率限制，短信挑战有有效期及尝试次数上限。支付密码连续输错五次后，账号支付和敏感操作被冻结，保留登录、必要查询及客服能力，解冻由工作人员按关联工单与身份核验流程处理。

客户、员工及运维文字入口均执行凭据预检。明确表达的密码或安全码先由本地规则阻断；进入远端决策前，不透明数字、字母及混合字符串替换为长度与形态标记。主模型异常时尝试备用模型，不安全、不确定或无有效判定的消息不交给业务助手。支付密码通过独立确认卡输入，仅供本次短期授权使用。

3.2 敏感操作确认与防重放

助手执行敏感操作前，展示收款方、金额、费用及业务后果等核对字段。分项 AA 确认同时展示活动总额、本人份额和待收总额，保持展示口径与分摊结果一致。

执行授权绑定所有者、会话、工具名、调用编号、参数摘要及运行轮次，并限制有效时间。执行前先消费授权，再发起异步请求，防止并行重放；用户取消、停止运行或参数变化后，未执行授权不能继续使用。

正式提交前重新核对报价或相关业务快照。手续费、汇率、收款信息或业务状态变化时要求重新确认。银行后端仍独立检查支付密码、余额和对象归属，助手的确认结果不能跳过银行校验。

3.3 交易一致性与幂等控制

账务更新在工作单元中结合数据库事务、锁和约束执行，失败回滚。支付密码失败次数通过专门的安全记录路径保留，避免随失败交易一并丢失。余额、流水与相关审计按既定事务边界持久化。

列入网关范围的关键写操作必须携带幂等键。相同编号与相同请求返回既有结果，同一编号对应不同参数时拒绝提交。Agent 写请求使用与会话、调用和工具绑定的编号。

网页在 sessionStorage 中仅保存随机操作编号及摘要，不保存请求正文或支付密码。网络失败时保留编号，同请求重试复用原编号；同路径参数改变前，先核查或封存旧操作，再要求用户重新确认，避免在结果不明时直接发起新的资金请求。

支出预算在扣款前检查命中平台的每日额度，月度分类目标用于支出跟踪。预算不冻结资金，也不替代余额、卡片限额和其他交易校验。

3.4 数据存储与会话保护

敏感业务负载、卡片秘密及持久化助手会话采用 AES-256-GCM，附加认证数据绑定记录上下文。密文被篡改或在错误上下文中解密时拒绝处理。

会话快照不保存银行令牌，敏感卡片秘密事件在写入前被拒绝。Agent 子进程不继承银行数据库、会话数据库及相应密钥等非必要凭据。姓名、手机号及部分流水检索字段仍以明文字段保存，其保护依赖数据库权限、访问审计和备份管理。

工具结果与遥测配置有脱敏处理。助手对外错误采用统一映射，内部异常和语音上游响应不原样返回前端。运维执行审计记录操作者、参数指纹、风险判断、人工授权及执行结果，不直接保存完整命令和文件正文。

3.5 页面内容与文件导出

模型 Markdown 不启用原始 HTML 注入，不自动加载 Markdown 图片，限制链接协议，并关闭公式渲染的可信扩展，减少脚本执行和自动外带路径。

CSV 导出对不可信文本中的公式前缀添加文本标记，处理前导空白和控制字符，保持引号、分隔符及换行的标准转义。文本防护不改变实际数值类型的导出值。

导出文件须由已登录客户生成。下载时同时验证登录身份和一次性票据归属；其他客户访问不消费原票据。票据短期有效、单次使用，网页通过携带当前登录态的请求取得文件，裸链接不能单独作为下载授权。

助手跨域默认仅允许当前来源，需要跨域的环境通过明确名单放行。反向代理配置包含防内容嗅探、引用来源限制、页面嵌入限制、基础内容安全策略及 HSTS，并处理独立 location 的响应头继承关系。

3.6 运维 Agent 执行控制

原生工具先核对运维身份、运行状态、工具名单和参数，再执行确定性风险检查。文件访问检查真实路径及受保护目标，执行前再次核对，防止确认期间通过符号链接更换目标。工具参数不能自行扩大沙箱权限。

风险网关结合规则与 Clef 决策模型。规则禁止的操作不能通过人工确认绕过；模型不可用、结果无效或输入过长时转人工核对。Shell、文件写入、网络请求与进程终止操作即使被模型判为低风险，也必须逐次人工确认。

运维授权绑定完整参数、员工及运行轮次，限时单次消费，并记录审核、授权和执行结果。停止会话后，未执行授权失效。

3.7 安卓敏感输入、展示与本地恢复

支付密码及多类数字字段使用应用内绘制的键盘，避免这些输入经过系统输入法。支付密码采用掩码显示，数字键位在打开时重新排列；金额输入同时保留数字零和小数点，并限制金额格式。登录密码输入方式以当前实现为准，其保护范围单独核对。

登录页、安全键盘路径、银行卡页和交易详情页设置窗口安全标志，限制截屏与录屏；离开受保护页面时撤销相应标志。完整卡号与安全码仅在获准查看后短时保留，达到可见期限后隐藏。窗口保护不作为对抗已被高权限控制设备的保证。

会话令牌通过 Android Keystore 保管的 AES-GCM 密钥加密，每次加密使用随机初始化向量，偏好文件保存密文。读取旧明文格式时迁移到新格式并移除旧字段，密钥或密文不可用时解密返回失败。姓名、昵称等展示资料与令牌采用不同的保存策略；正式配置关闭系统备份。

资金请求发起前先保存随机操作编号与操作名称，按客户身份摘要区分，不记录请求正文或支付密码。存在未核查操作时，阻止直接发起新的资金请求；网络中断或进程重启后，先向服务端核查或封存原编号，再继续办理。页面读缓存仅在内存中保留，退出登录时清空。

3.8 安卓传输、更新与组件暴露

正式配置同时通过应用清单与网络安全配置禁止明文流量。调试配置仅为指定本地联调地址设置例外。银行请求默认使用 HTTPS，令牌置于 Authorization 请求头，并设置连接与读取超时。

正式包只接受 HTTPS 更新清单及安装包地址。下载完成后按清单提供的 SHA-256 核对文件，并比对下载包与当前应用的签名证书摘要；签名无法取得或身份不一致时删除文件并拒绝安装。更新包经非导出的 FileProvider 临时授予系统安装器读权限，后续安装由系统处理。

安卓 Markdown 为链接生成及导航增加协议限制，禁止 javascript、data 等非许可协议。富文本仍使用开启 JavaScript 的 WebView 和受限高度回传接口，属性编码与文件访问范围还需继续收紧。

主清单声明网络与安装包请求权限，导出组件主要为启动 Activity。正式包关闭自动登录，开发变体使用独立包名，发布时核对签名及合并后的组件配置。

3.9 登录来源与设备审计

客户会话与认证审计记录请求来源和设备特征。只有来自本机反向代理的请求才采信 x-real-ip；直连请求以连接对端地址为准，避免客户端通过自填请求头伪造来源。登录失败记录也从实际请求上下文取得相应信息。

设备名称结合平台和客户端特征生成。地址按本机或私网、公网地址及 IPv6 等类别展示，不借助外部归属地服务推测城市。审计增强字段不可用时使用兼容写入路径，避免附加元数据阻断登录；新增字段的部署与权限仍按数据库变更流程管理。

4 剩余风险与处置要求

4.1 多模态内容与模型外发（中）

文字凭据判定前的本地隐藏减少了数值和不透明字符串外发，但不代表所有正文已经匿名化。业务助手仍需处理获准提交的消息；交易分类还会使用对手方、摘要、渠道和金额等要素。

图片未执行与文字相同的本地凭据扫描，语音先交由识别上游处理，再对转写文字预检。用户若在图片或音频中包含密码等敏感信息，仍存在外发风险。图片与语音交互继续保留，需进一步增加本地 OCR、音频敏感内容识别及发送前遮盖能力，并明确供应商数据留存和访问规则。

4.2 运维宿主读取与网络权限（高，条件性）

运维工具虽经过网关与人工确认，Shell 和网络工具仍具有执行间接操作的能力。所用 local sandbox 包包含系统写权限限制实现，但读取范围、网络出口及宿主账号权限仍须与部署策略配合。

本项风险取决于运行账号实际拥有的资源权限及工具可触达路径，不等同于已发生隔离绕过。应使用独立低权限账号或容器，将银行凭据、数据目录和控制资源与工具工作区隔离，限制网络出口，并对高影响操作优先采用结构化接口。人工终端须单独落实相同原则。

4.3 同源脚本与明文字段保护（中，条件性）

sessionStorage 与内存中的有效令牌仍可被有权限的同源脚本读取。当前 Markdown 渲染限制降低了模型内容注入风险，但其他页面依赖、扩展脚本及浏览器环境仍需持续检查。应逐步完善内容安全策略、依赖漏洞核查和页面输入输出检查。

数据库中的检索字段及备份同样包含敏感业务信息。应落实最小权限角色、受限备份访问、保留期限和恢复演练，确认审计记录的修改与删除权限受到限制；不能将部分负载加密表述为数据库整体加密。

4.4 发布配置与接口兼容性

安全措施是否在运行环境生效，还取决于反向代理、服务账号、密钥配置和实际数据库权限。仓库中的配置不能单独证明所有部署实例已采用相同策略。

发布时应核对最终响应头与允许来源，确认新下载流程能够携带客户身份，并检查各调用方是否按关键写操作要求提供幂等键。接口收紧应与客户端及 Agent 版本共同发布，防止旧调用方因缺少安全参数而无法办理业务。

4.5 安卓富文本与更新边界（中）

链接协议限制已建立，但 Markdown 链接目标写入 HTML 属性前，仍需独立处理引号等属性字符。协议白名单不能代替属性编码。WebView 的 JavaScript、文件访问和本地资源导航应按实际功能进一步缩减，并覆盖属性注入与跳转场景验证。

安装包签名身份已在应用内比对。当前摘要检查仍以清单提供 SHA-256 为条件，应继续要求摘要存在且格式有效；摘要与清单同源，也不能代替签名身份判断。客户端依赖系统 TLS 栈，尚未加入证书固定。

4.6 设备环境与本地解锁

客户端未将 Root 检测、运行完整性校验、生物识别解锁或后台返回应用锁作为现有防护。加密保存令牌和限制截屏降低本地暴露面，但不能据此承诺已抵御高权限宿主、调试注入或无障碍滥用。

当前核对的登录密码输入仍经系统输入法，该链路不适用自绘数字键盘的隔离结论。支付密码和数字字段的自绘键盘保护分别核对。

5 安全验证结果

5.1 本地执行结果

本地回归覆盖身份与密码处理、授权判断、参数绑定、运维路径控制、会话持久化边界、业务共享逻辑及修复项。模型相关单元测试使用注入响应，接口夹具使用回环地址。

检查类别	总数	通过	失败	跳过
银行、共享业务及桥接测试	223	185	0	38
敏感操作授权插件	29	29	0	0
白名单与脱敏插件	17	17	0	0
安全行为与密文完整性探针	5	5	0	0
合计	274	236	0	38

此外，Markdown 渲染检查 23 项、支出预算检查 18 项及单资金账户检查 6 项通过。客户两份工具配置各核对 100 项，员工工具配置核对 21 项；网页及工作人员构建通过。额外脚本断言单独统计，不与上表混加。

5.2 关键验证结论

本地用例确认：缺少幂等键的关键写请求被拒绝；结果不明的网页操作编号可在刷新后复用，参数改变时阻断直接重提；他人不能消费导出票据；CSV 危险前缀按文本处理；AA 确认卡展示本人份额。

Agent 相关用例还覆盖授权重放及参数替换拒绝、符号链接目标变化拒绝、运维高影响工具强制确认、无效模型结果处理、敏感事件拒绝持久化、密文篡改与上下文错配拒绝，以及 HTTP 和事件错误收口。

38 项跳过项主要需要专用 PostgreSQL 测试库，或依赖原生运行时及浏览器的显式测试开关。相应验证应在可丢弃数据库中补充执行，重点复核跨进程持久化、完整账务事务和工作人员权限链路。此处记录本轮执行情况，不对项目此前测试作否定判断。

5.3 安卓核查与验证记录

安卓部分重新检查了清单、会话保存、请求传输、安全键盘、窗口标志、资金恢复、更新及 WebView 实现。移动端专项验证记录包括 release 合并清单关闭备份和明文流量、偏好文件仅保存加密令牌、银行卡页面限制截屏且退出后恢复，以及支付密码键位重排。这些设备与构建结果单独记录，不并入前述 274 项统计。

资金恢复工程包含设备侧测试，覆盖未核查记录的保留、客户隔离和并发发起限制。本次检查了测试源码，不将用例存在直接视为再次运行通过。本次补充执行登录来源审计测试，两项均通过，覆盖代理与直连来源、设备识别及旧库字段兼容。另次服务端全量记录为 179 项通过，属于另一套件口径，不与既有跨层回归及新增用例重复相加。

6 后续安全维护

优先落实运维宿主读取和网络隔离，完善图片、语音及模型外发数据的最小化处理。同步复核数据库实际角色、备份权限、最终响应头和关键写接口的调用方兼容性。安卓端继续完善 WebView 属性编码和资源访问限制，要求更新摘要完整有效，并复核登录密码输入链路。

安全变更应保留与威胁对应的自动化断言，同时验证正常业务。新增工具须明确角色、参数、确认方式、幂等要求和审计字段；新增敏感字段须检查页面展示、模型上下文、持久化与日志四条路径。

维护记录分别保存源码依据、测试结果与运行环境检查结果。风险状态以实际防护范围和验证证据更新，避免以配置文件存在、测试文件新增或模型判定结果替代安全措施的执行效果。